Análise de Segurança e Privacidade em Cenários de Data Lakehouse e Concessão de Crédito

Diego Arruda Torales, Guilherme Zanini da Silva

Universidade do Vale do Rio dos Sinos (Unisinos)
Av. Unisinos, 950 - Cristo Rei – 93022-750 – São Leopoldo – RS – Brazil

{diego.arruda.torales@outlook.com, guilhermezsilva@hotmail.com}

Abstract. *This paper analyzes information security and data privacy in two real-world big data scenarios: a corporate Data Lakehouse and a credit-granting process. The analysis identifies protected assets, incident impacts, privacy requirements, and prioritized controls for data at rest and in transit. The results indicate that encryption alone is insufficient and must be combined with data classification, least privilege, traceability, data minimization, and incident response throughout the data lifecycle.*

Resumo. *Este artigo analisa segurança da informação e privacidade de dados em dois cenários reais de grandes volumes de dados: uma plataforma corporativa Data Lakehouse e um processo de concessão de crédito. São identificados os ativos protegidos, os impactos de incidentes, os requisitos de privacidade e as práticas prioritárias para dados em repouso e em trânsito. A análise indica que a criptografia deve ser combinada com classificação, menor privilégio, rastreabilidade, minimização e resposta a incidentes durante todo o ciclo de vida dos dados.*

1. Introdução

A adoção de arquiteturas distribuídas e serviços em nuvem ampliou a capacidade das organizações de coletar, integrar e analisar dados provenientes de diferentes sistemas. Ao mesmo tempo, a concentração e a replicação dessas informações aumentam a superfície de exposição e podem ampliar os efeitos de vazamentos, alterações indevidas e indisponibilidade. A ENISA ressalta que os ativos de Big Data não se limitam aos dados: incluem infraestrutura, algoritmos, resultados analíticos, mecanismos de segurança e os profissionais envolvidos [ENISA 2016].

A segurança da informação busca preservar confidencialidade, integridade e disponibilidade. A privacidade, por sua vez, está associada ao controle sobre a coleta, utilização, compartilhamento e conservação de dados pessoais. Embora relacionadas, essas dimensões não são equivalentes: um ambiente pode impedir acessos externos e ainda utilizar dados pessoais de maneira excessiva ou incompatível com a finalidade informada. Por isso, os controles precisam abranger todo o ciclo de vida da informação e incorporar a privacidade desde a concepção [Cavoukian 2011].

Este trabalho analisa dois cenários reais relacionados ao tratamento de grandes volumes de dados: uma plataforma corporativa Data Lakehouse e um processo de concessão de crédito. Para cada cenário são apresentados os dados e ativos que exigem proteção, os

possíveis impactos de incidentes, os mecanismos de garantia da privacidade e as práticas de segurança priorizadas para dados em repouso e em trânsito.

2. Cenário 1: plataforma corporativa Data Lakehouse

2.1. Apresentação do cenário

O primeiro cenário corresponde a uma plataforma corporativa que integra dados provenientes de diferentes ambientes e sistemas, incluindo SAP BW, SAP HANA e Salesforce. Pipelines orquestrados pelo Apache Airflow extraem periodicamente as informações e as disponibilizam em um Data Lakehouse. No Azure Databricks, jobs de processamento distribuído validam, padronizam, integram e aplicam regras de negócio. Os dados são organizados nas camadas Raw, Silver, Gold e Publish: a Raw preserva a informação próxima ao formato de origem; a Silver reúne dados tratados; a Gold contém dados consolidados segundo regras de negócio; e a Publish oferece conjuntos preparados para consumo por ferramentas de BI, aplicações corporativas e projetos de ciência de dados.

Esse fluxo processa dados de clientes, produtos, pedidos, faturamento, preços, custos e margens. A proteção é importante porque um incidente pode alcançar simultaneamente diferentes áreas e produtos de dados. A exposição da Raw pode revelar registros em sua maior granularidade; uma alteração na Silver ou na Gold pode propagar resultados incorretos; e permissões inadequadas na Publish podem disponibilizar informações a públicos incompatíveis com sua finalidade. Assim, a arquitetura deve preservar a tríade confidencialidade, integridade e disponibilidade sem desconsiderar os princípios da LGPD.

2.2. Dados e ativos que exigem proteção e impactos de incidentes

Entre os ativos protegidos estão dados pessoais de clientes e contatos, como nome, e-mail, telefone e identificadores; informações corporativas confidenciais, como preços, descontos, pedidos, faturamento, custos e margens; e ativos técnicos, como código dos pipelines, credenciais, chaves, logs, metadados e regras de transformação. Dados comerciais não são necessariamente dados pessoais sensíveis nos termos da LGPD, mas continuam estratégicos para a organização. Já registros que identificam pessoas naturais estão sujeitos aos princípios e direitos previstos na legislação [Brasil 2018].

O comprometimento da confidencialidade pode causar exposição de dados pessoais e perda de vantagem competitiva. A violação da integridade pode modificar valores, filtros ou regras e induzir dashboards, aplicações e modelos analíticos a produzir decisões incorretas. A perda de disponibilidade pode interromper cargas e serviços dependentes. Credenciais expostas aumentam ainda o risco de movimentação entre sistemas, enquanto a adulteração de logs dificulta a investigação e a responsabilização.

2.3. Garantia da privacidade

A privacidade deve começar pela minimização: cada pipeline deve coletar apenas os campos necessários para uma finalidade definida. Dados pessoais devem ser mascarados em desenvolvimento e homologação e, quando a identificação direta não for necessária,

pseudonimizados. A possibilidade de reidentificação por cruzamento entre tabelas deve ser considerada, pois a variedade e a ligação entre bases podem reduzir a efetividade de anonimizações isoladas [ENISA 2016].

O acesso deve variar conforme a camada. A Raw exige maior restrição por conter dados detalhados; Silver e Gold devem ser acessíveis somente às equipes que tratam e validam as informações; e a Publish deve expor apenas os atributos necessários a cada consumidor. Políticas de retenção e descarte precisam abranger arquivos, tabelas temporárias, logs e cópias de segurança. Essas medidas materializam Privacy by Design ao incorporar privacidade ao desenho do fluxo, em vez de adicioná-la depois que os dados já foram replicados [Cavoukian 2011].

2.4. Práticas de segurança priorizadas

Considerando o impacto potencial sobre diferentes sistemas, camadas e consumidores, as práticas a seguir são apresentadas em ordem de prioridade. A classificação e o controle de acesso ocupam a primeira posição porque os demais controles dependem da identificação dos dados, de seus responsáveis e das finalidades autorizadas de uso.

1. **Classificação e controle de acesso**: mapear dados e responsáveis, aplicar menor privilégio, segregar funções e restringir o acesso por camada e finalidade.
2. **Proteção de credenciais**: armazenar senhas, tokens e chaves em cofres de segredos, realizar rotação e impedir sua inclusão em código ou logs.
3. **Proteção em trânsito e em repouso**: utilizar canais autenticados e criptografados entre fontes, Airflow, Data Lakehouse, Databricks e consumidores; criptografar arquivos, tabelas, discos, backups e áreas temporárias, mantendo gestão segura das chaves [Microsoft 2026].
4. **Segregação, integridade e rastreabilidade:** separar desenvolvimento, homologação e produção; versionar e revisar alterações em DAGs, jobs e notebooks; validar esquema, volume, duplicidade e reconciliação com as fontes; e manter a linhagem dos dados para identificar sua origem e acompanhar as transformações realizadas entre as camadas Raw, Silver, Gold e Publish.
5. **Auditoria, continuidade e resposta**: registrar acessos e mudanças, detectar atividades anormais, manter backups testados e definir procedimentos de contenção, investigação, recuperação e comunicação.

3. Cenário 2: concessão de crédito

3.1. Apresentação do cenário

Neste cenário, avalia-se o processo de aprovação e concessão de crédito por uma instituição financeira, uma operação crítica que exige a coleta, o armazenamento e o processamento de um alto volume de dados pessoais e sensíveis. O fluxo integra dados provenientes de cadastros internos, birôs de crédito e sistemas de open finance. Motores de regras e modelos analíticos processam continuamente essas informações para avaliar

o perfil do cliente e determinar o risco, utilizando variáveis fundamentais como histórico de inadimplência, renda, idade e pontuações de crédito (scores).

A proteção nesse ecossistema é indispensável, pois um incidente afeta diretamente a vida econômica dos clientes e a conformidade da instituição. A arquitetura deve preservar a confidencialidade, a integridade e a disponibilidade da base de avaliação, garantindo que o processamento massivo de informações ocorra em total conformidade com a legislação de proteção de dados.

3.2. Dados e ativos que exigem proteção e impactos de incidentes

Os ativos protegidos englobam informações de identificação pessoal (como nome, idade e CPF); dados financeiros e comportamentais críticos (renda, histórico de pagamentos, dívidas ativas, patrimônio, garantias e scores de crédito); além de ativos técnicos (algoritmos de scoring e credenciais de integração).

O impacto de um incidente envolvendo esses dados seria severo em múltiplas frentes. O comprometimento da confidencialidade pode resultar em fraudes financeiras contra os clientes, exposição indevida da situação econômica dos titulares, graves danos à reputação da instituição e severas sanções legais e regulatórias. Já a violação da integridade pode adulterar históricos, induzindo o sistema a aprovar créditos indevidos (gerando prejuízo) ou a negar solicitações de forma arbitrária (gerando discriminação injusta). Além disso, falhas na proteção podem permitir o acesso abusivo por funcionários curiosos a dados de figuras públicas ou conhecidos.

3.3. Garantia da privacidade

A garantia da privacidade no processamento destas informações deve ser fundamentada na abordagem de Privacidade por Design (Privacy by Design), incorporando a proteção de dados nativamente (por padrão) na arquitetura tecnológica dos motores de crédito desde o seu planejamento. O tratamento desse alto volume de dados deve respeitar rigorosamente os princípios da LGPD, com destaque para:

Finalidade: O tratamento de dados, como renda e histórico financeiro, deve ocorrer apenas para propósitos legítimos, específicos e explícitos ligados à análise de crédito.

Necessidade: A coleta e o uso devem se restringir estritamente às variáveis necessárias para a avaliação, implementando a minimização de dados.

Não discriminação: Garantir que o cruzamento de informações (como idade e região) pelos algoritmos não resulte em práticas discriminatórias, ilícitas, perpetuação de vieses, ou exclusões abusivas contra o proponente.

3.4. Práticas de segurança priorizadas

Para proteger esse ecossistema e mitigar os riscos apresentados, o ambiente deve priorizar os seguintes controles e conceitos de segurança da informação:

1. **Controle de Acesso e Confidencialidade:** Para assegurar que a informação confidencial seja acessada somente por pessoas e processos estritamente autorizados, o ambiente deve implementar uma forte Autenticação (para determinar e provar que o usuário ou sistema consultando a base é legítimo) combinada a uma Autorização rigorosa (para garantir que esse usuário tenha os

privilégios corretos e necessários para visualizar o histórico daquele cliente específico).

2. **Criptografia de Dados:** O sistema deve utilizar algoritmos de criptografia fortes para transformar o texto claro em texto cifrado. Isso garante que atributos críticos, como os valores exatos de renda, dívidas e scores, fiquem ilegíveis e não possam ser utilizados por partes não autorizadas caso ocorra um vazamento ou interceptação.
3. **Proteção nos Diferentes Estados da Informação:** É imprescindível aplicar controles de segurança consistentes para proteger os dados independentemente do seu estado. Isso abrange a proteção dos dados em repouso (quando as informações financeiras estão armazenadas nos bancos de dados e discos rígidos da instituição) e dos dados em trânsito (quando as informações trafegam através da rede de dados durante consultas a APIs de birôs de crédito externos).
4. **Anonimização e Pseudonimização em Exposições Analíticas:** Para a realização de estudos, análises estatísticas e treinamento de modelos analíticos ou de machine learning, deve-se utilizar a anonimização e a pseudonimização. Essas técnicas garantem que relatórios e ambientes de desenvolvimento utilizem informações desassociadas da identidade direta do titular, reduzindo substancialmente o risco de vazamento em uso analítico.
5. **Auditoria e Rastreabilidade (Logs):** Registro imutável de todas as consultas aos históricos de crédito, alterações nos motores de regras e decisões automatizadas, permitindo a identificação rápida de anomalias, acessos abusivos e viabilizando a investigação de incidentes.

4. Conclusão

Os cenários analisados demonstram que a proteção de grandes volumes de dados depende de controles técnicos, organizacionais e jurídicos aplicados de forma integrada. No Data Lakehouse, o principal desafio é impedir que uma falha em credenciais, permissões ou pipelines se propague pelas camadas e alcance múltiplos consumidores. Já na concessão de crédito, além de evitar vazamentos e fraudes, é vital garantir a não discriminação e o respeito estrito à finalidade e necessidade no uso de dados pessoais e financeiros do proponente.

Em ambos os casos, a criptografia é necessária, mas insuficiente quando aplicada isoladamente. Classificação, menor privilégio, minimização, segregação, auditoria e resposta a incidentes formam uma defesa em profundidade. A prioridade deve partir do conhecimento dos ativos e das finalidades, pois controles desconectados do fluxo real podem proteger a infraestrutura sem impedir usos excessivos ou decisões baseadas em dados incorretos.

Por fim, segurança e privacidade devem acompanhar os dados da coleta ao descarte. A adoção de Privacy by Design e o atendimento aos princípios da LGPD reduzem a exposição e tornam a proteção parte da arquitetura e do processo decisório, contribuindo para preservar a organização e os direitos das pessoas afetadas.

Referências

Brasil (2018). Lei nº 13.709, de 14 de agosto de 2018. Lei Geral de Proteção de Dados Pessoais. Diário Oficial da União, Brasília, DF.

Cavoukian, A. (2011). Privacy by Design: The 7 Foundational Principles. Information and Privacy Commissioner of Ontario, Canada.

ENISA (2016). Big Data Threat Landscape and Good Practice Guide. European Union Agency for Network and Information Security.

ENISA (2024). ENISA Threat Landscape 2024. European Union Agency for Cybersecurity.

Microsoft (2026). Azure data security and encryption best practices. Microsoft Learn. Disponível em: https://learn.microsoft.com/en-us/azure/security/fundamentals/data-encryption-best-practices. Acesso em: 13 set. 2026.

Shirey, R. (2007). Internet Security Glossary, Version 2. RFC 4949. Internet Engineering Task Force.

ARAUJO (2024). Tomada de crédito segura: A relevância da segurança da informação no setor financeiro